Task-1: Vulnerability Assessment Report

- Target: testaspnet.vulnweb.com

Presented by

Muhammad Shadab Shaik
CIN: FIT/MAR26/CS7147

www.linkedin.com/in/muhammad-shadab-shaik-3aa9b9223

Executive Summary

Overview
A safe, non-intrusive security check was done on the website to find possible weaknesses without affecting its normal operation.

Security Rating: Medium–High Risk
The website is working, but some important security issues make it vulnerable to attacks and possible data leaks.

Main Issues

- Outdated Server: The site uses an old version of IIS (8.5), which may not have the latest security fixes.
- Information Exposure: The server reveals details about its system, which can help attackers target it.
- Missing Security Protections: Important security settings (like HSTS and CSP) are not in place, increasing the risk of hacking attempts such as XSS and data interception.

Recommendation
Upgrade the server to a newer, supported version and add standard security protections to better protect the website and its users.

AUDIT METHODOLOGY

Assessment Type:
Passive external security testing
Framework Used:
OWASP Top 10 and NIST Cybersecurity Framework

Approach
The test was done using a “black box” method, meaning the tester had no inside knowledge of the system—just like a real attacker. Only safe and non-intrusive methods were used, so the website stayed fully operational. No hacking attempts, password attacks, or service disruptions were performed.

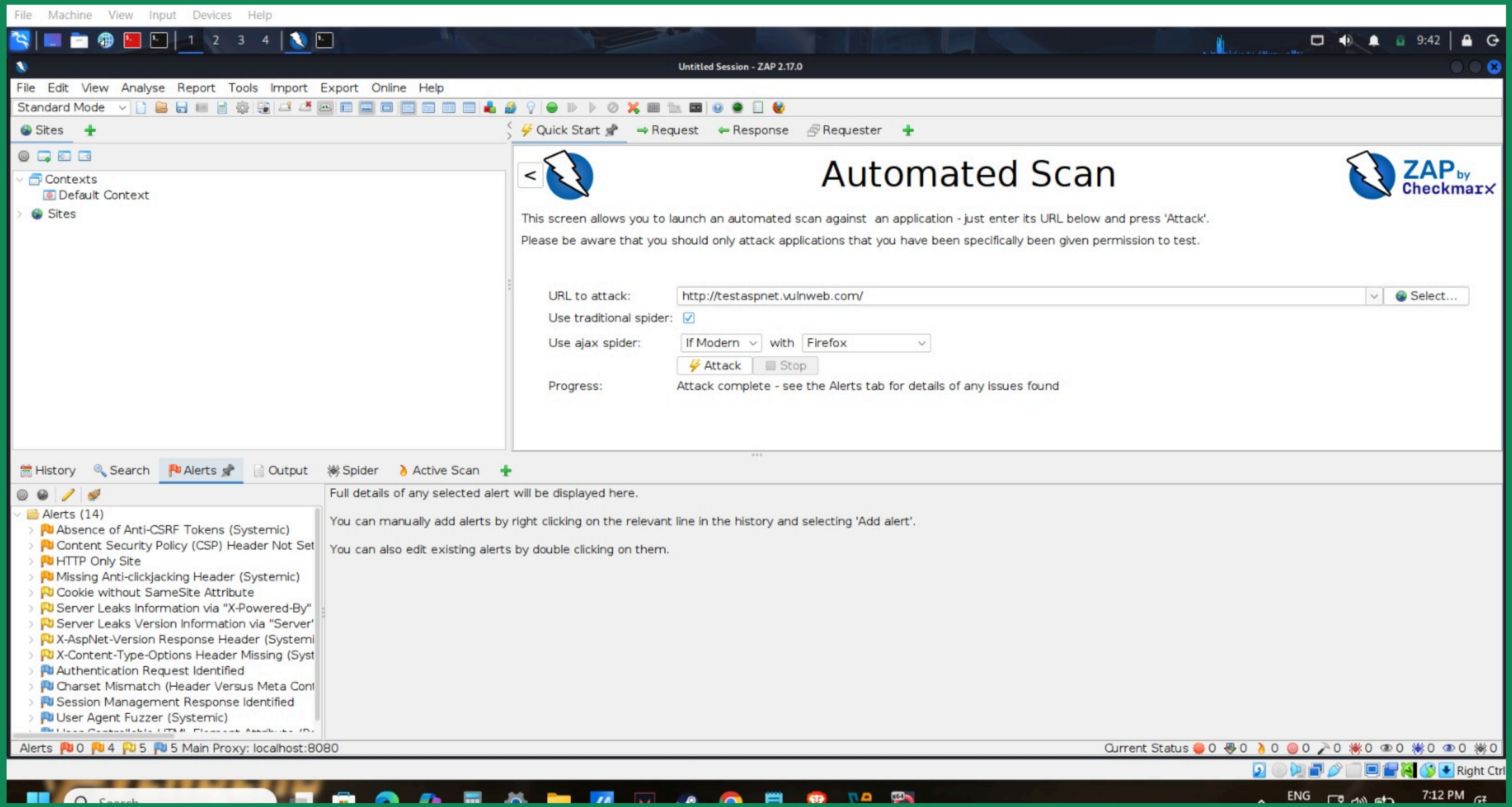
Tools Used
The following tools were used in a secure testing setup:

- Nmap: To find open ports and identify server details
- OWASP ZAP: To scan for common web security issues like missing protections
- Browser Developer Tools: To manually check code, cookies, and server responses
- Canva: To present findings clearly in a visual and professional way

Risk Levels
Issues found are ranked based on their impact:

- High: Serious risk, easy to exploit, major impact
- Medium: Important issue, but needs certain conditions to exploit
- Low: Small issue, may still help attackers gather information

VULNERABILITY FINDINGS



Finding	Risk Level	Description & Business Impact
Server Information Leakage	Medium	The server explicitly reveals "X-Powered-By" and "X-AspNet-Version" headers. This gives attackers a "map" of the exact software versions to target with known exploits.
Missing Anti-Clickjacking	Medium	The "X-Frame-Options" header is missing. This allows attackers to "frame" the site, potentially tricking users into clicking invisible buttons (UI Redressing).
Lack of Anti-CSRF Tokens	High	The system lacks protection against Cross-Site Request Forgery. An attacker could force a logged-in user to perform actions (like changing a password) without their knowledge.
Insecure Cookie Attributes	Low	Cookies are missing "SameSite" and "HttpOnly" attributes. This increases the risk of session hijacking and cross-site tracking.
Missing CSP Header	Low	No Content Security Policy (CSP) is defined. This is a primary defense against Cross-Site Scripting (XSS) attacks.

REMEDIATION STRATEGY

Based on the vulnerabilities identified in Section 3.0, the following technical controls are recommended to harden the security posture of testaspnet.vulnweb.com.

Immediate Security Hardening

Implement Security Headers: Configure the web server to include missing defensive headers:
Content-Security-Policy: To prevent unauthorized script execution (XSS).
X-Frame-Options: DENY: To block Clickjacking attempts.
X-Content-Type-Options: nosniff: To prevent MIME-type sniffing.
Secure Cookie Management: Update application code to ensure all session cookies use the *HttpOnly, Secure*, and *SameSite=Lax* flags to prevent session hijacking.
Anti-CSRF Protection: Implement unique, cryptographically strong anti-CSRF tokens for all state-changing requests (forms, logins, etc.).

Infrastructure & Information Masking

Disable Version Broadcasting: Modify the *web.config* or IIS settings to remove the *X-Powered-By, X-AspNet-Version,* and *Server headers.*
System Updates: Plan a migration from Microsoft IIS 8.5 to a modern, currently supported version of Windows Server to ensure receipt of critical security patches.

This assessment has highlighted several areas where the application is vulnerable to modern web attacks. By implementing the remediation steps outlined above, the organization can significantly reduce its attack surface and better protect user data.

Analyst Signature:
Muhammad Shadab Shaik

Contact Information:
www.linkedin.com/in/muhammad-shadab-shaik-3aa9b9223